

Top 10 web hacking techniques of 2020



James Kettle
Director of Research
[@albinowax](#)



Published: Wednesday, 24 February 2021 at 15:02 UTC

Updated: Friday, 26 February 2021 at 09:53 UTC



Welcome to the Top 10 (novel) Web Hacking Techniques of 2020, our [annual community-powered effort](#) to identify the must-read web security research released in the previous year.

Over the past few weeks, we've seen the community [nominate 54 innovative papers](#), posts and presentations, then cast their votes to whittle the list down to 15 potential candidates. Finally, an expert panel consisting of [Nicolas Grégoire](#), [Soroush Dalili](#), [Filedescriptor](#), and myself have voted in the 15 finalists to create the official top 10.

We've seen an undeniable increase in quality research since 2019, making the community vote even more competitive than usual. Numerous respectable posts didn't make the final 15; some that narrowly missed out include [Secret Fragments](#), [AST Injection](#), [XSS without arbitrary JavaScript](#), and my own [Web Cache Entanglement](#) amid countless others.

Other than the overall improved quality, two other themes stood out this year. The community vote demonstrated a strong interest in novel attacks exploiting proxies and multi-layered architectures; including follow-ups to [HTTP Desync Attacks](#) and some exciting novel techniques which we'll see shortly. We also observed that the best attack research is increasingly dipping below the application layer, whether it's abusing TLS, chunked encoding, PDF internals or packet fragmentation.

Without further ado, let's begin the countdown.

10 - WAF evasion techniques

Much of [WAF evasion techniques](#) is simply a robust but widely known methodology for understanding and evading Web Application Firewalls. What makes this stand out is [Paweł Hałdrzyński's](#) gloriously low-level malformed chunk technique. There's surely more where that came from, and it may have impact beyond merely bypassing WAFs...

9 - Attacking MS Exchange Web Interfaces

We all love a good class break, but good research isn't just about broadly applicable techniques. [Attacking MS Exchange Web Interfaces](#) by [Arseniy Sharoglazov](#) stunned the entire panel while demonstrating the extreme depth you can achieve on a single target. If you run into this technology it will be invaluable, and it also lays extensive groundwork for future research.

8 - ImageMagick - Shell injection via PDF password

In this post, [Alex](#) targets the [notorious ImageMagick library](#), twisting its vast array of features to create a polyglot that, with the help of a somewhat malicious bug report, gets RCE.

The research discovery process is often glossed over and at risk of seeming a bit magical to outsiders, but Alex does a great job of covering his discovery journey, making this post valuable for people looking to get into research as well as those of us who just want a shell.

7 - Unauthenticated RCE on MobileIron MDM

Speaking of research journeys, this novel-esque post from top-10 frequenter [Orange Tsai](#) shows a master at work. [Unauthenticated RCE on MobileIron MDM](#) follows his journey as he selects a target and chains multiple research-grade techniques in his pursuit of a shell. There's nothing like a case study exploiting a high profile target to prove research isn't just theoretical, and Orange provides one in style by landing RCE on Facebook. Awesome work, as usual.

6 - Smuggling HTTP headers through reverse proxies

[Using underscores in header names](#) has lurked on the edge of community awareness for quite a few years - for example, it's already implemented in [Param Miner](#) - so it's great to see [Robin Verton](#) drag it into the light with a case study showing critical impact! Even better that he uses it to crack SSL Client Authentication, which is far from a soft target.

5 - NAT Slipstreaming

The panel was a bit conflicted about whether [NAT Slipstreaming](#) qualifies as a web hacking technique, but we had no doubts about the quality of the research.

[Samy Kamkar](#) used IP fragmentation to trick routers into interpreting part of a browser-issued HTTP request as a SIP packet and opening up the victim's NAT. This cross-layer, cross-discipline attack beautifully demonstrates the value of familiarity with underlying protocols and adjacent fields.

4 - When TLS Hacks You

[SSRF](#) often has a critical impact, but if there's no convenient web services to target with it, it can appear frustratingly harmless. [When TLS Hacks You](#) is an SNI injection-inspired technique by [Joshua Maddux](#) which elegantly combines DNS rebinding and TLS session resumption to exploit internal services that don't speak HTTP. As filedescriptor put it, *he brought gopher:// back!*

This is essential reading for anyone stuck with an SSRF, and we're looking forward to seeing this technique appearing in exploit writeups in future.

3 - Attacking Secondary Contexts in Web Applications

Modern websites are a highly entangled mess of proxies, load balancers, and micro services. We've already seen quite a few [path traversal attacks](#) exploiting this mess. What [Sam Curry](#) brings with [Attacking Secondary Contexts in Web Applications](#) ([slides](#), [recording](#)) is the exceptional clarity of someone who has spent a lot of time exploiting this stuff. The quality of explanation and numerous case studies make this an outstanding, must-watch presentation for newbies and experts alike.

2 - Portable Data exFiltration: XSS for PDFs

Everyone knows what happens if you embed user input in HTML without encoding it, and in recent years people have also exploited servers that render user-uploaded PDFs using HTML. However, thanks to PDF's horrifying markup, nobody has publicly explored what happens when user input is embedded in a PDF, until now. In [Portable Data exFiltration](#), [Gareth Heyes](#) tackles the format and stretches PDF parsers to go from PDF link injection to document theft, JavaScript execution and SSRF.

Needless to say I didn't vote for this myself due to a [conflict of interest](#).

1 - H2C Smuggling: Request Smuggling Via HTTP/2 Cleartext

Given that no browsers support it, you could almost forget that HTTP/2 cleartext (H2C) exists, right up until [Jake Miller](#) unveiled [H2C Smuggling](#). This is an all-new technique that abuses H2C-unaware front-ends to create a tunnel to backend systems, enabling attackers to bypass front-end rewrite rules and exploit internal HTTP headers.

It's conceptually similar to the previous year's [WebSocket Smuggling](#) but looks significantly more practical. Request tunneling exploitation is an emerging art so this one may be a slow burn, but we anticipate some serious carnage in future.

Ultimately this research proves that, just like Gopher, this already-obsolete protocol is a gift to attackers. Massive congratulations to Jake Miller and Bishop Fox on a well-deserved winner!

Conclusion

As ever, this top 10 list just scratches the surface and we recommend web security enthusiasts read the [entire nomination list](#).

We're looking forward to seeing what the community shares comes out this year! If you're interested in reading research the moment it's released, you might want to check out [@PortSwiggerRes](#) and [r/websecurityresearch](#), both of which were created to promote and curate quality web research. If you're tempted to attempt some research yourself, we have some [advice on becoming a web security researcher](#). Also, you may want to check out previous year's top tens: [2019](#), [2018](#), [2017](#), [2015](#), [2014](#), [2013](#), [2012](#), [2011](#), [2010](#), [2009](#), [2008](#), [2007](#), [2006](#).

We'd like to conclude with a massive thanks to the entire community - without your research, nominations and votes this wouldn't be possible.

Till next year!

- by [James Kettle](#), with insights from [Nicolas Grégoire](#), [Soroush Dalili](#) and [Fildescriptor](#).

Top 10 Hacking Techniques

[← Back to all articles](#)

Related Research



Burp Suite

Web vulnerability scanner
Burp Suite Editions
Release Notes

Vulnerabilities

Cross-site scripting (XSS)
SQL injection
Cross-site request forgery
XML external entity injection
Directory traversal
Server-side request forgery

Customers

Organizations
Testers
Developers

Company

About
Careers
Contact
Legal
Privacy Notice
Modern Slavery Statement

Insights

Web Security Academy
Blog
Research
Engineering

 PortSwigger

 Follow us

© 2026 PortSwigger Ltd.

